COMPTIA SECURITY+ SY0-701 | DOMAIN 4 · SECURITY OPERATIONS (28%)

Security+ 4.1 · Hardening Targets

Mestre CyberSec · **Lesson 4.1 — Hardening Targets** (10:11) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Executive Lesson Summary:** Alvos: wireless (WPA2/3-Enterprise); mobile (MDM, anti-jailbreak); servers (fechar porta, remover serviço); workstations; IoT (segmentar!); ICS/OT (air gap/DMZ); cloud (IAM+SG).

💡 Key Exam Highlights & Critical Concepts

- IoT (câmera, sensor): a superfície MAIS esquecida — segmentar
- ICS/OT (fábrica): air gap ou DMZ industrial

🎯 Exam Tips & Typical CompTIA Scenarios

- 'segmenting IoT devices'=security control for IoT

🧯 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 4.1 — Hardening Targets)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• WPA2/WPA3-Enterprise

Enterprise Wi-Fi security using 802.1X/EAP with a RADIUS authentication server, providing unique credentials per user instead of a shared PSK. WPA3-Enterprise adds stronger encryption and management-frame protection.

⚠️ ***Exam Trap:*** *Se a questão mencionar rede wireless corporativa, 802.1X, RADIUS ou credenciais individuais, pense em WPA2/WPA3-Enterprise. Personal usa PSK; Enterprise usa autenticação centralizada.*

• Mobile Device Management (MDM)

A centralized solution to enforce security policies on mobile devices, including encryption, screen locks, application control, remote wipe, and jailbreak/root detection. It helps harden BYOD and corporate-owned mobile devices.

⚠️ ***Exam Trap:*** *MDM é o controle típico para hardening móvel. Se a questão citar BYOD, políticas de dispositivo, remote wipe ou anti-jailbreak, a resposta provavelmente envolve MDM.*

• Jailbreaking/Rooting (N/A)

The process of bypassing manufacturer restrictions on iOS or Android to gain privileged/root access. It removes security controls, increases malware risk, and is often detected or blocked by MDM policies.

⚠️ ***Exam Trap:*** *Jailbreak/root em dispositivo móvel indica enfraquecimento de segurança. Em prova, associe a MDM, negação de acesso corporativo ou wipe do dispositivo.*

• Server Hardening (N/A)

The practice of securing servers by removing unnecessary services, closing unused ports, patching the OS/applications, using host firewalls, and applying least privilege. The goal is to reduce the attack surface.

⚠️ ***Exam Trap:*** *Servidor seguro começa com reduzir funcionalidades: fechar portas e remover serviços antes de ajustar aplicações. Não confunda com apenas instalar antivírus.*

• Least Functionality / Port and Service Removal (N/A)

A hardening principle where systems run only the services, ports, protocols, and applications required for their role. Unused ports and services are disabled or removed to reduce exploitable attack surface.

⚠️ ***Exam Trap:*** *Gatilho clássico: 'reduzir superfície de ataque' em servidores/workstations = desabilitar portas e serviços não usados. Também chamado de least functionality.*

• IoT Segmentation

Placing Internet of Things devices on separate VLANs, subnets, or firewall zones to prevent them from directly reaching sensitive systems. This limits lateral movement if an IoT device is compromised.

⚠️ ***Exam Trap:*** *A prova frequentemente associa 'segmenting IoT devices' como controle de segurança para IoT. Câmeras e sensores são a superfície mais esquecida; segmente-os.*

• ICS/OT Air Gap / Industrial DMZ

A security architecture for industrial control systems/operational technology that isolates them from corporate or Internet networks using a physical air gap or an industrial DMZ with strict firewall rules. It protects critical industrial processes from cyber threats.

⚠️ ***Exam Trap:*** *Se a questão mencionar fábrica, SCADA, PLC, ICS ou OT, procure air gap ou DMZ industrial. Não trate ICS/OT como workstation comum.*

• Cloud IAM and Security Groups (IAM/SG)

Cloud hardening through identity and access management least privilege plus security group firewall rules that control inbound and outbound traffic to cloud resources. IAM governs who can do what; security groups govern network access.

⚠️ ***Exam Trap:*** *Hardening em nuvem = IAM com privilégio mínimo + Security Groups restritivos. Se a questão perguntar controle de acesso lógico na nuvem, pense em IAM; para tráfego de rede, Security Groups.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Disabling Unneeded Services & Ports (Least Functionality)

🏠 **Real-World Analogy:** Imagine a heritage bank building that originally had 15 side doors, 20 ground windows, and 3 roof hatches. To protect the vault, the manager bricks up all 14 side doors, bolts the windows, and funnels all foot traffic exclusively through one guarded front revolving door equipped with a metal detector.

🔍 **Root Cause & Background:** Operating systems ship with dozens of legacy utilities activated for broad compatibility. Every idle background daemon represents an unmonitored entry point that attackers can exploit without the security team's awareness.

🛡️ **GRC Auditor Perspective:** The auditor enforces the Principle of Least Functionality: every open port and active service must have an approved business justification in the service registry, strictly forbidding cleartext legacy protocols like Telnet (port 23) and FTP (port 21).

⚠️ **How CompTIA Tests This:** Exam trigger: 'Disabling unnecessary ports, protocols, and services to reduce vulnerability footprint' = Attack Surface Reduction / Least Functionality. 'Replacing port 23 with port 22' = Replacing insecure Telnet with encrypted SSH.

📌 Service Accounts & Least Privilege / gMSA

🏠 **Real-World Analogy:** A contract gardener hired solely to rake leaves in the corporate courtyard. Handing him the master key to the CEO's executive safe simply because it was easier than cutting a dedicated key for the garden gate is an invitation to catastrophe.

🔍 **Root Cause & Background:** Engineers often run automated background application accounts with full Domain Admin privileges to avoid the inconvenience of fine-tuning granular access permissions.

🛡️ **GRC Auditor Perspective:** The auditor inspects service accounts to confirm that interactive console logons are disabled, automated password rotation is enforced via Group Managed Service Accounts (gMSA), and permissions strictly follow least privilege.

⚠️ **How CompTIA Tests This:** Exam trigger: 'Non-human account running background applications without interactive login capabilities' = Service Account. 'Mitigating credential theft from automated processes' = Group Managed Service Accounts (gMSA).

📌 Securing IoT, ICS/SCADA & Operational Technology

🏠 **Real-World Analogy:** The mechanical turbine pumps of a hydroelectric dam constructed 40 years ago. They function reliably mechanically, but if you plug an open office Ethernet cable into their controller or try installing a heavy desktop antivirus, the pump crashes and the reservoir floods.

🔍 **Root Cause & Background:** Operational Technology (OT) and IoT appliances prioritize uninterrupted availability and deterministic real-time control, running low-power chips that cannot run endpoint agents and rarely receive firmware updates.

🛡️ **GRC Auditor Perspective:** The auditor reviews network segmentation policies (dedicated IoT VLANs, physical/logical air-gaps, industrial DMZs complying with ISA/IEC 62443) preventing any administrative office PC from routing packets directly into Programmable Logic Controllers (PLCs).

⚠️ **How CompTIA Tests This:** Exam trigger: 'Best security control to protect smart building sensors and legacy factory floor equipment' = Network segmentation / Dedicated isolated VLAN. Distractor trap: attempting to install heavy enterprise EDR agents on resource-constrained IoT sensors.

📌 Removing Default Credentials & Unnecessary Software

🏠 **Real-World Analogy:** Purchasing a high-tech digital lock for your front door but leaving the manufacturer's factory PIN '1234' active alongside the neon sticker on the handle that says 'default password is 1234'. Any passing stranger walks right in.

🔍 **Root Cause & Background:** Hardware appliances ship with standardized factory credentials like 'admin/password'. Adversaries deploy automated scanning bots that blast public IPs with known credential dictionaries within minutes of a device going live.

🛡️ **GRC Auditor Perspective:** The auditor checks provisioning sign-off sheets verifying that default vendor usernames and passwords were replaced with complex unique secrets prior to network connection, and that bundled bloatware was purged.

⚠️ **How CompTIA Tests This:** Exam trigger: 'First action an administrator must take when commissioning a new network switch or router' = Change default credentials. 'Vector responsible for the Mirai botnet explosion' = Factory default credentials on IoT webcams.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Disabling operating system ports and services that have no legitimate business operational need	**Principle of Least Functionality**
System account utilized by automated background services configured with no interactive human logon rights	**Service Account / gMSA**
Optimal defensive control to secure smart building IoT sensors and IP cameras from office network threats	**Isolated VLAN Network Segmentation**
Mandatory first step when unboxing and initializing a brand-new router or network security appliance	**Change Default Credentials**
Mission-critical industrial networks operated with complete physical and logical isolation from corporate IT	**Air-Gap / Industrial DMZ**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A hospital's corporate Wi-Fi currently uses a single shared passphrase for all staff and contractors. Auditors require centralized, per-user authentication and the ability to revoke access immediately when an employee leaves. Which wireless hardening approach best meets these requirements?

A) Enable WPA2-Personal with a longer complex pre-shared key rotated quarterly

B) Hide the SSID and enable MAC address filtering for known clinical devices

C) Deploy WPA3-Enterprise with 802.1X/EAP against the directory service

D) Move the Wi-Fi to an open guest network protected only by a captive portal

QUESTION 2 · EXAM SCENARIO

A company issues Android and iOS smartphones to field technicians. The security team discovers that some technicians have removed manufacturer restrictions to install unsigned applications and modify system files. Which MDM control should be enforced to reduce this risk?

A) Jailbreak/root detection with automated compliance actions

B) Remote email synchronization only during business hours to eliminate single points of operational failure

C) Containerization of corporate email and calendar data across all hybrid on-premises and cloud clusters

D) Full-device encryption with a minimum PIN length without disrupting production workload availability

QUESTION 3 · EXAM SCENARIO

A finance department runs an internal Linux reporting server. A scan shows that SSH, HTTPS, FTP, Telnet, and SMB are listening. The server only needs to provide a secure web report to a few internal analysts. Which server-hardening action best follows least functionality?

A) Keep all services but place the server behind a network firewall to eliminate single points of operational failure

B) Remove or disable FTP, Telnet, SMB, and SSH; keep only HTTPS with restricted access

C) Install a host intrusion prevention system and leave the services enabled without disrupting production workload availability

D) Change all default service banners and rename the administrative account to enforce least privilege and reduce attack surfaces

QUESTION 4 · EXAM SCENARIO

A company's Windows workstations have been infected repeatedly when users download and install unauthorized software. The security team wants a control that prevents unknown executables from running even if a user has local administrator rights. Which workstation hardening control is most appropriate?

A) Full-disk encryption with TPM across all hybrid on-premises and cloud clusters

B) Host-based firewall rules blocking inbound SMB

C) Security awareness training focused on phishing

D) Application allowlisting enforced by policy

QUESTION 5 · EXAM SCENARIO

A manufacturer installed Internet-connected cameras, environmental sensors, and smart locks on the same VLAN as corporate laptops and ERP servers. A recent camera firmware vulnerability could allow an attacker to move laterally. Which hardening step best reduces this risk?

A) Place IoT devices on a separate VLAN with firewall rules that deny access to corporate systems

B) Change all default IoT passwords and enable WPA3 on the corporate wireless network to enforce least privilege and reduce attack surfaces

C) Disable unused switch ports and enable DHCP snooping on the corporate VLAN through automated configuration orchestration pipelines

D) Require multifactor authentication for users accessing the ERP application while ensuring strict audit log retention compliance

QUESTION 6 · EXAM SCENARIO

An electric utility needs to send operational data from its OT network to a corporate analytics platform for reporting. The OT team refuses a direct connection because PLCs must not be reachable from the corporate network. Which architecture best supports this requirement?

A) Create a site-to-site VPN that lets corporate analysts reach PLCs directly to enforce least privilege and reduce attack surfaces

B) Connect OT and corporate networks with a flat Layer 2 VLAN for simplicity through automated configuration orchestration pipelines

C) Deploy an industrial DMZ with separate firewalls and brokered data transfer between IT and OT

D) Use a single firewall with any/any rules between IT and OT to reduce latency using standardized security content automation profiles

QUESTION 7 · EXAM SCENARIO

A cloud administrator launches an AWS EC2 instance for a web application. The security group allows SSH and RDP from 0.0.0.0/0, and the application uses an access key stored in a configuration file. Which combination best hardens this cloud workload?

A) Enable MFA for all IAM users and leave the security group rules unchanged through automated configuration orchestration pipelines

B) Move the instance to a private subnet and continue using the embedded access key while ensuring strict audit log retention compliance

C) Create a network ACL that allows all traffic but logs connections for auditing using standardized security content automation profiles

D) Restrict security group rules to required ports and trusted source ranges; replace static access keys with IAM roles

QUESTION 8 · EXAM SCENARIO

A cloud team notices that all developers share an IAM user with AdministratorAccess to simplify deployments. Auditors require each developer to have only the permissions needed for their tasks. Which hardening action should be taken first?

A) Enable MFA on the shared account and rotate its password every 30 days while ensuring strict audit log retention compliance

B) Create individual IAM identities and assign least-privilege policies based on job roles

C) Restrict the shared account to a specific source IP range in a security group to prevent unauthorized configuration drift across nodes

D) Store the shared account credentials in a password manager for the team across all managed enterprise endpoints

QUESTION 9 · EXAM SCENARIO

A company allows employees to use personal smartphones for corporate email and calendar. Legal requires that the company be able to remove corporate data remotely without erasing employees' personal photos and messages. Which MDM capability best meets this requirement?

A) Corporate containerization with selective wipe

B) Full-device remote wipe for any noncompliant device

C) Jailbreak detection that blocks all personally installed applications

D) Device-level encryption enforced only during business hours

QUESTION 10 · EXAM SCENARIO

A security assessment of a public-facing Linux server finds that direct root login over SSH is allowed, password authentication is enabled, and a default vendor account still exists. The server must remain remotely manageable by administrators. Which hardening action should be prioritized?

A) Change the SSH port to 2222 and keep password authentication enabled to prevent unauthorized configuration drift across nodes

B) Install an additional antivirus agent and schedule weekly full scans across all managed enterprise endpoints

C) Enable verbose SSH banners that warn unauthorized users against access while maintaining continuous telemetry and monitoring

D) Disable direct root SSH login, enforce key-based authentication, and remove or disable the default account

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — Deploy WPA3-Enterprise with 802.1X/EAP against the directory service

WPA3-Enterprise uses 802.1X/EAP, allowing individual credentials and centralized revocation through the directory. PSK, hidden SSID, MAC filtering, and captive portals do not provide strong per-user authentication and immediate revocation.

Question 2: Option A — Jailbreak/root detection with automated compliance actions

Jailbreak/root detection identifies compromised mobile OS integrity and can block access, wipe corporate data, or quarantine the device. Containerization and encryption are valuable but do not detect or remediate a rooted/jailbroken device.

Question 3: Option B — Remove or disable FTP, Telnet, SMB, and SSH; keep only HTTPS with restricted access

Least functionality means disabling or removing every service, protocol, and port not required for the server's role. FTP, Telnet, SMB, and even SSH are unnecessary if only HTTPS is needed; firewalls, banners, and HIPS do not remove unnecessary attack surface.

Question 4: Option D — Application allowlisting enforced by policy

Application allowlisting permits only approved executables to run, directly blocking unauthorized or unknown software. Encryption, firewall rules, and training are useful but do not prevent execution of unapproved applications.

Question 5: Option A — Place IoT devices on a separate VLAN with firewall rules that deny access to corporate systems

IoT devices should be segmented from corporate and sensitive systems using separate VLANs and firewall ACLs. Password changes, WPA3, and port security help but do not prevent lateral movement from an IoT device to ERP servers.

Question 6: Option C — Deploy an industrial DMZ with separate firewalls and brokered data transfer between IT and OT

An industrial DMZ isolates OT from IT while allowing controlled data exchange through brokered services or replication. Direct VPN access to PLCs, flat networks, and any/any firewall rules expose critical OT systems.

Question 7: Option D — Restrict security group rules to required ports and trusted source ranges; replace static access keys with IAM roles

Cloud hardening requires least-privilege security groups and temporary IAM roles instead of long-lived embedded access keys. MFA, private subnets, and logging help, but they do not fix overly broad network access or static credentials.

Question 8: Option B — Create individual IAM identities and assign least-privilege policies based on job roles

IAM hardening starts with unique identities and least privilege. MFA, rotation, IP restrictions, and password managers do not correct shared administrative credentials or excessive permissions.

Question 9: Option A — Corporate containerization with selective wipe

Containerization separates corporate data from personal data, enabling selective wipe of only corporate email, calendar, and documents. Full-device wipe would erase personal data, and jailbreak detection or encryption does not meet the selective removal requirement.

Question 10: Option D — Disable direct root SSH login, enforce key-based authentication, and remove or disable the default account

Hardening a remote Linux server includes disabling direct root SSH, using key-based authentication, and removing or disabling unnecessary default accounts. Changing ports, banners, or adding antivirus does not address these critical authentication and account weaknesses.